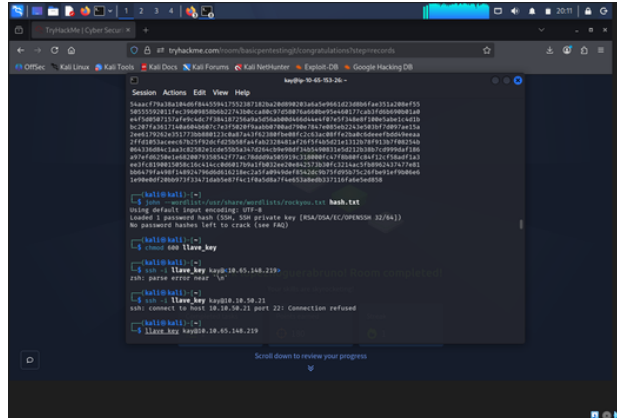


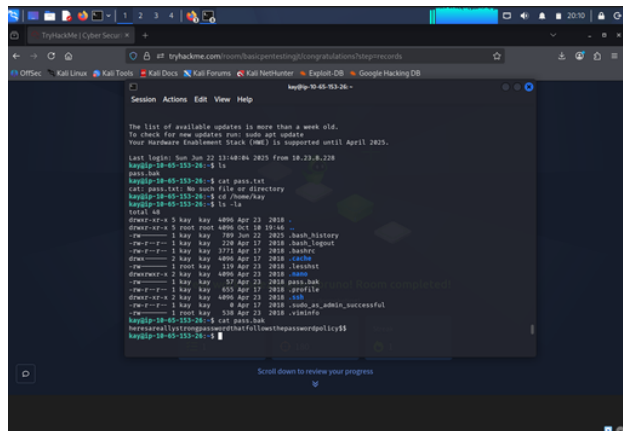
Fase 3: Extracción y Cracking de Credenciales

Aprovechando la mala configuración descubierta, logré leer el contenido del archivo `id_rsa` (la llave privada de kay). Copié esta llave a mi entorno local en Kali Linux. Como la llave estaba protegida por una frase de paso (passphrase), utilicé la herramienta `ssh2john` para extraer el hash de la llave y prepararla para su ruptura.



Fase 4: Escalada de Privilegios y Explotación Final

Con la llave privada y su respectiva contraseña en mi poder, ajusté los permisos del archivo local (chmod 600) y me conecté exitosamente por SSH como el usuario kay, logrando así el máximo nivel de acceso en la máquina. Al inspeccionar su directorio, encontré un archivo de respaldo de contraseñas.



Conclusiones y Recomendaciones de Mitigación

La máquina presentaba una cadena de vulnerabilidades clásicas que derivaron en un compromiso total del sistema. Para asegurar este servidor, recomiendo aplicar inmediatamente las siguientes mitigaciones:

1. **Políticas de Contraseñas Seguras:** El usuario `jan` utilizaba una clave fácilmente deducible. Se debe implementar una política de contraseñas robustas y configurar bloqueos de cuenta tras múltiples intentos fallidos (ej. `Fail2Ban`) para mitigar ataques de fuerza bruta.
2. **Principio de Menor Privilegio (Permisos de Archivos):** Las carpetas `.ssh` y los archivos de claves privadas jamás deben tener permisos de lectura o ejecución para el grupo u otros usuarios. Se debe aplicar estrictamente `chmod 700` a las carpetas `.ssh` y `chmod 600` a los archivos `id_rsa`.

Flag Final Obtenido: heresareallystrongpasswordthatfollowsthepasswordpolicy\$\$